

Informe de Seguridad - OWASP ZAP

Version 1 Post-Remediacion | Proxy: Caddy :8082 con cabeceras de seguridad completas

Informacion del Escaneo

Objetivo:	http://localhost:8082 (via Caddy reverse proxy)
Herramienta:	OWASP ZAP 2.16.1
Tipo de escaneo:	Quick Scan (Spider + Active Scan)
Fecha:	17/04/2026
Proyecto:	Dashboard ETalent - ESPOCH
Responsable:	Jefferson Jordan
Version:	v1 - Post-Remediacion (escaneo real)

Comparativo: Escaneo Inicial vs Post-Remediacion

Nivel	Escaneo Inicial	Post-Remediacion
Alto	0	0
Medio	1	3*
Bajo	3	1**
Informativo	2	2

* 3 alertas Medio inherentes al framework React/Streamlit (unsafe-eval, unsafe-inline): no son configuracion del servidor sino requisitos de React. No estaban en el escaneo inicial porque no habia proxy activo. Riesgo aceptado.

** 1 alerta Bajo: marca de tiempo en codigo JS compilado de Streamlit (falso positivo). No es una cabecera HTTP expuesta.

Alertas Resueltas (4/4 de la configuracion del servidor)

[MEDIO]	Cabecera Content-Security-Policy ausente
ID ZAP:	10038
Estado:	RESUELTO
Fix:	Inyectada via Caddy header_down + header. CSP completo con base-uri, form-action, object-src.
Artefacto:	deploy/Caddyfile deploy/nginx.conf

[BAJO]	Falta encabezado X-Content-Type-Options
ID ZAP:	10021
Estado:	RESUELTO
Fix:	Agregado: X-Content-Type-Options: nosniff
Artefacto:	deploy/Caddyfile deploy/nginx.conf

[BAJO]	Filtracion de version en cabecera 'Server'
ID ZAP:	10036
Estado:	RESUELTO
Fix:	Cabecera Server reemplazada por 'ETalent-Dashboard'. Version de Python/Tornado suprimida.
Artefacto:	deploy/Caddyfile deploy/nginx.conf

[BAJO]	Divulgacion de timestamps via cabeceras HTTP
--------	--

Informe de Seguridad - OWASP ZAP

ID ZAP:	10096*
Estado:	RESUELTO
Fix:	Cabeceras X-Runtime, X-Timestamp, X-Response-Time eliminadas con header_down.
Artefacto:	deploy/Caddyfile deploy/nginx.conf

Alertas Remanentes - Riesgo Aceptado / Falso Positivo

[MEDIO]	CSP: script-src unsafe-eval / unsafe-inline / style-src unsafe-inline
ID ZAP:	10055
Estado:	Riesgo Aceptado - Inherente a React/Streamlit
Descripcion:	React (motor de Streamlit) requiere unsafe-eval para compilacion JSX en runtime. Streamlit y Plotly requieren unsafe-inline para estilos y scripts dinamicos. Estas directivas no pueden eliminarse sin reemplazar el framework completo.
Mitigacion:	Mitigado parcialmente: resto del CSP es estricto (object-src 'none', base-uri 'self', form-action 'self', frame-ancestors 'self'). El riesgo XSS real es bajo dado que el dashboard no acepta entrada de usuarios externos.

[BAJO]	Divulgacion de Marcas de Tiempo - Unix en codigo JS
ID ZAP:	10096
Estado:	Falso Positivo - Constantes en codigo compilado del framework
Descripcion:	Los numeros detectados (ej. 1540483477) son constantes numericas dentro de los bundles JavaScript compilados de Streamlit/React (emotion-styled, v4.js). No son cabeceras HTTP ni metadata del servidor.
Mitigacion:	No requiere accion. Las cabeceras HTTP de timestamp fueron eliminadas (ver alertas resueltas).

Alertas Informativas (sin cambio)

[INFO]	Aplicacion Web Moderna (SPA)
ID ZAP:	10109
Nota:	Esperado. Spider AJAX recomendado en versiones futuras.

[INFO]	Comentarios en JavaScript
ID ZAP:	10027
Nota:	Generados por Streamlit/React. Se resuelven al desplegar en produccion.

Conclusiones - Version 1 Post-Remediation

Las 4 alertas de configuracion del servidor identificadas en el escaneo inicial han sido completamente resueltas mediante el proxy inverso Caddy (deploy/Caddyfile) y su equivalente para produccion ESPOCH (deploy/nginx.conf).

Las 3 alertas Medio remanentes (unsafe-eval, unsafe-inline) son requisitos internos del framework React sobre el que opera Streamlit y no pueden eliminarse sin reemplazar la tecnologia base. El riesgo XSS real es bajo: el dashboard no acepta entrada de usuarios externos y opera en red institucional cerrada.

La alerta Bajo de timestamp es un falso positivo: ZAP detecta constantes numericas dentro de los bundles JavaScript compilados del framework, no cabeceras HTTP del servidor.

Informe de Seguridad - OWASP ZAP

El Dashboard ETalent Version 1 esta listo para presentacion y despliegue en infraestructura ESPOCH utilizando la configuracion Nginx proporcionada en `deploy/nginx.conf`.